

Safeguard 16.11: Leverage Vetted Modules or Services for Application Security Components

Asset Type: Software	Security Function: Protect	IG2 IG3
-----------------------------	-----------------------------------	-----------------------

Leverage vetted modules or services for application security components, such as identity management, encryption, auditing, and logging. Using platform features in critical security functions will reduce developers’ workload and minimize the likelihood of design or implementation errors. Modern operating systems provide effective mechanisms for identification, authentication, and authorization and make those mechanisms available to applications. Use only standardized, currently accepted, and extensively reviewed encryption algorithms. Operating systems also provide mechanisms to create and maintain secure audit logs.

Safeguard 16.12: Implement Code-Level Security Checks

Asset Type: Software	Security Function: Protect	IG3
-----------------------------	-----------------------------------	------------

Apply static and dynamic analysis tools within the application life cycle to verify that secure coding practices are being followed.

Safeguard 16.13: Conduct Application Penetration Testing

Asset Type: Software	Security Function: Detect	IG3
-----------------------------	----------------------------------	------------

Conduct application penetration testing. For critical applications, authenticated penetration testing is better suited to finding business logic vulnerabilities than code scanning and automated security testing. Penetration testing relies on the skill of the tester to manually manipulate an application as an authenticated and unauthenticated user.

Safeguard 16.14: Conduct Threat Modeling

Asset Type: Software	Security Function: Protect	IG3
-----------------------------	-----------------------------------	------------

Conduct threat modeling. Threat modeling is the process of identifying and addressing application security design flaws within a design, before code is created. It is conducted through specially trained individuals who evaluate the application design and gauge security risks for each entry point and access level. The goal is to map out the application, architecture, and infrastructure in a structured way to understand its weaknesses.

CONTROL 17

Incident Response Management

Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack.

Safeguard 17.1: Designate Personnel to Manage Incident Handling

Asset Type: Users	Security Function: Respond	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Designate one key person, and at least one backup, who will manage the enterprise’s incident handling process. Management personnel are responsible for the coordination and documentation of incident response and recovery efforts and can consist of employees internal to the enterprise, service providers, or a hybrid approach. If using a service provider, designate at least one person internal to the enterprise to oversee any third-party work. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.2: Establish and Maintain Contact Information for Reporting Security Incidents

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain contact information for parties that need to be informed of security incidents. Contacts may include internal staff, service providers, law enforcement, cyber insurance providers, relevant government agencies, Information Sharing and Analysis Center (ISAC) partners, or other stakeholders. Verify contacts annually to ensure that information is up-to-date.

Safeguard 17.3: Establish and Maintain an Enterprise Process for Reporting Incidents

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain an documented enterprise process for the workforce to report security incidents. The process includes reporting timeframe, personnel to report to, mechanism for reporting, and the minimum information to be reported. Ensure the process is publicly available to all of the workforce. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.4: Establish and Maintain an Incident Response Process

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a documented incident response process that addresses roles and responsibilities, compliance requirements, and a communication plan. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.5: Assign Key Roles and Responsibilities

Asset Type: Users	Security Function: Respond	IG2	IG3
-------------------	----------------------------	-----	-----

Assign key roles and responsibilities for incident response, including staff from legal, IT, information security, facilities, public relations, human resources, incident responders, analysts, and relevant third parties. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.6: Define Mechanisms for Communicating During Incident Response

Asset Type: Users	Security Function: Respond	IG2	IG3
-------------------	----------------------------	-----	-----

Determine which primary and secondary mechanisms will be used to communicate and report during a security incident. Mechanisms can include phone calls, emails, secure chat, or notification letters. Keep in mind that certain mechanisms, such as emails, can be affected during a security incident. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.7: Conduct Routine Incident Response Exercises

Asset Type: Users	Security Function: Recover	IG2	IG3
-------------------	----------------------------	-----	-----

Plan and conduct routine incident response exercises and scenarios for key personnel involved in the incident response process to prepare for responding to real-world incidents. Exercises need to test communication channels, decision making, and workflows. Conduct testing on an annual basis, at a minimum.

Safeguard 17.8: Conduct Post-Incident Reviews

Asset Type:	Users	Security Function:	Recover	IG2	IG3
-------------	-------	--------------------	---------	-----	-----

Conduct post-incident reviews. Post-incident reviews help prevent incident recurrence through identifying lessons learned and follow-up action.

Safeguard 17.9: Establish and Maintain Security Incident Thresholds

Asset Type:	Documentation	Security Function:	Recover	IG3
-------------	---------------	--------------------	---------	-----

Establish and maintain security incident thresholds, including, at a minimum, differentiating between an incident and an event. Examples can include: abnormal activity, security vulnerability, security weakness, data breach, privacy incident, etc. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

CONTROL 18

Penetration Testing

Test the effectiveness and resiliency of enterprise assets through identifying and exploiting weaknesses in controls (people, processes, and technology), and simulating the objectives and actions of an attacker.

Safeguard 18.1: Establish and Maintain a Penetration Testing Program

Asset Type:	Documentation	Security Function:	Govern	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----

Establish and maintain a penetration testing program appropriate to the size, complexity, industry, and maturity of the enterprise. Penetration testing program characteristics include scope, such as network, web application, Application Programming Interface (API), hosted services, and physical premise controls; frequency; limitations, such as acceptable hours, and excluded attack types; point of contact information; remediation, such as how findings will be routed internally; and retrospective requirements.

Safeguard 18.2: Perform Periodic External Penetration Tests

Asset Type: Network	Security Function: Detect	IG2 IG3
---------------------	---------------------------	---------

Perform periodic external penetration tests based on program requirements, no less than annually. External penetration testing must include enterprise and environmental reconnaissance to detect exploitable information. Penetration testing requires specialized skills and experience and must be conducted through a qualified party. The testing may be clear box or opaque box.

Safeguard 18.3: Remediate Penetration Test Findings

Asset Type: Network	Security Function: Protect	IG2 IG3
---------------------	----------------------------	---------

Remediate penetration test findings based on the enterprise's documented vulnerability remediation process. This should include determining a timeline and level of effort based on the impact and prioritization of each identified finding.

Safeguard 18.4: Validate Security Measures

Asset Type: Network	Security Function: Protect	IG3
---------------------	----------------------------	-----

Validate security measures after each penetration test. If deemed necessary, modify rulesets and capabilities to detect the techniques used during testing.

Safeguard 18.5: Perform Periodic Internal Penetration Tests

Asset Type: Network	Security Function: Detect	IG3
---------------------	---------------------------	-----

Perform periodic internal penetration tests based on program requirements, no less than annually. The testing may be clear box or opaque box.

The Center for Internet Security, Inc. (CIS®) makes the connected world a safer place for people, businesses, and governments through our core competencies of collaboration and innovation.

We are a community-driven nonprofit, responsible for the CIS Controls® and CIS Benchmarks™, globally recognized best practices for securing IT systems and data. We lead a global community of IT professionals to continuously evolve these standards and provide products and services to proactively safeguard against emerging threats. Our CIS Hardened Images® provide secure, on-demand, scalable computing environments in the cloud.

CIS is home to the Multi-State Information Sharing and Analysis Center® (MS-ISAC®), the trusted resource for cyber threat prevention, protection, response, and recovery for U.S. State, Local, Tribal, and Territorial government entities, and the Elections Infrastructure Information Sharing and Analysis Center® (EI-ISAC®), which supports the rapidly changing cybersecurity needs of U.S. elections offices.



 www.cisecurity.org

 info@cisecurity.org

 518-266-3460

 Center for Internet Security

 CenterforIntSec

 @CISecurity

 TheCISecurity

 cisecurity